

Plataforma de impacto social — estratégia de produto e blueprint de implementação

Da ideia de “Tinder do Impacto Social” a um sistema confiável de gestão de oportunidades, grants e evidências

RELATÓRIO ESTRATÉGICO + BLUEPRINT TÉCNICO

Brasil primeiro | 4 de outubro de 2026 | Preparado por Manus AI

DECISÃO EM UMA LINHA

Construir um SaaS B2B para gerir programas de grants e investimento social — com descoberta curada, due diligence, aprovações e evidências — e não um marketplace aberto de swipe ou pagamentos.

O que este documento entrega

- Recomendação de produto, ICP, personas, proposta de valor e caminho de receita.
- Leitura crítica de concorrentes e substitutos no Brasil e no exterior.
- MVP priorizado, motor de compatibilidade, inteligência fiscal e arquitetura de IA.
- Blueprint técnico, segurança, LGPD, dados, testes, roadmap, propriedade intelectual e auditoria de escopo.

Escopo: análise e especificação estratégica. Não é parecer fiscal/jurídico nem implementação de software, código ou build de lojas.

Sumário

- Decisão recomendada
- O que o mercado sugere — e o que ainda não prova
- Problema, visão e posicionamento
- Clientes, usuários e trabalhos a realizar
- Concorrência e substitutos
- MVP e experiência de produto
- Rede de prestadores e acompanhamento articulado
- Motor de compatibilidade — especificação inicial
- Inteligência fiscal — motor separado e cauteloso
- Modelo de negócio e preço a validar
- Go-to-market e validação de product-market fit
- Arquitetura de referência
- IA: onde usar e onde não usar
- LGPD, compliance e governança
- Evidências, pagamentos e integridade
- Segurança, ameaças e controles
- Roadmap, testes e critérios de saída
- Web, Google Play e Apple App Store
- Propriedade intelectual e portabilidade
- Registro de dependências externas
- Auditoria final simulada
- Auditoria de release e escopo desta entrega

Decisão recomendada

Não construir um “Tinder” de projetos nem começar por um marketplace transacional aberto. O produto recomendado é um **SaaS B2B de gestão de programas de investimento social e grants, com descoberta curada de oportunidades, due diligence, trilha de decisão e acompanhamento de evidências.** O “match” é um recurso explicável dentro do fluxo de seleção, não a promessa central nem uma verdade automática.

A primeira versão deve atender empresas, institutos e fundações que administram múltiplos editais ou investimentos sociais. A OSC usa um portal gratuito, assistido e mobile-friendly para cadastrar seu perfil, uma oportunidade concreta, orçamento, documentos, metas e evidências. A empresa organiza critérios, aprova, monitora e presta contas em um único fluxo. A plataforma não custodiará nem distribuirá dinheiro no MVP; os recursos seguirão diretamente por conta bancária apropriada do beneficiário ou por prestador de pagamento contratado, conforme mecanismo e orientação jurídica aplicáveis.

A proposta de valor é **reduzir o custo e o tempo de encontrar, avaliar, financiar e acompanhar iniciativas**, gerando um registro consistente de “por que foi selecionada”, “o que foi financiado” e “qual evidência sustenta o resultado”. A vantagem defensável não é um algoritmo isolado. É a combinação de taxonomia e dados normalizados, histórico de decisão e execução, confiança documental, workflows configuráveis e interoperabilidade.

Decisões-chave:

- Produto inicial: software de workflow para programas corporativos, mais catálogo fechado/curado, e não feed de swipe.
- Pagador: empresa, instituto ou fundação com orçamento e programas recorrentes. OSC é usuária e beneficiária do fluxo; sua cobrança deve ser evitada no início.
- Receita principal: contrato SaaS anual e taxa de implantação/serviços claramente delimitados. Evitar comissão percentual sobre aportes como modelo inicial.
- Fiscal: não inferir benefício fiscal por similaridade nem garantir economia tributária. Elegibilidade determinística, fontes versionadas e decisão/parecer humano.
- Tecnologia: aplicação web responsiva/PWA primeiro; backend modular; PostgreSQL; armazenamento privado de documentos; provedor de pagamento externo apenas quando necessário. Aplicativos nativos ficam para uma necessidade demonstrada.
- IA: extração, classificação assistida, rascunho e recuperação de informação. Não aprova OSC, não decide elegibilidade legal/fiscal, não calcula tributo final e não substitui diligência.
- MVP: um comprador âncora, um território, um programa de financiamento e aproximadamente 5–10 oportunidades cadastradas. Três OSCs são úteis para testar usabilidade, mas não bastam para validar cobertura de um mercado ou um efeito de rede.

O que o mercado sugere — e o que ainda não prova

O Brasil tem uma base muito heterogênea de organizações. O relatório do Ipea com dados de referência de maio de 2025 aponta mais de 2,5 milhões de vínculos formais de trabalho

em OSCs em 2024 e que mais de 80% das organizações não mantêm vínculos formais. Isso indica escala social, mas também orçamento restrito, capacidade documental desigual e risco de desenhar um onboarding complexo demais. [1]

No Censo GIFE 2022–2023, 137 de 167 associados responderam; os respondentes reportaram R\$ 4,8 bilhões investidos em 2022. O BISC, por sua vez, informa que a coleta de 2024 reuniu dados de 328 empresas e 19 institutos e fundações corporativas. São sinais de um campo institucional existente — **não são o tamanho total do mercado endereçável, nem demonstram disposição de pagar por esta solução.** [2] [3]

O maior problema comercial é o equilíbrio de dois lados: a empresa paga apenas se houver projetos suficientemente confiáveis, aderentes e executáveis; OSCs só mantêm dados atualizados se receberem acesso concreto a oportunidades, orientação ou redução de trabalho. Portanto, não começar com “efeito de rede” como premissa. Vender primeiro um workflow a um comprador âncora e operar a curadoria manualmente para aprender.

O problema mais promissor a validar é menos “descobrir a causa perfeita” e mais **administrar o funil inteiro**: publicação ou recebimento de propostas, triagem, conflito de interesses, parecer, aprovação, compromisso, execução, evidências, prestação de contas e relatório. Plataformas já atendem partes desse ciclo. A lacuna a provar é a integração prática entre o contexto brasileiro de OSCs e incentivos, critérios corporativos e evidência pós-aporte, sem criar aconselhamento fiscal automático.

Problema, visão e posicionamento

Problem statement. Empresas e fundações que financiam impacto social têm dificuldade de estruturar critérios consistentes, descobrir iniciativas comparáveis, verificar documentos e acompanhar resultados. OSCs têm capacidade limitada para traduzir necessidades locais em propostas padronizadas e responder repetidamente a cadastros e prestações de contas distintos. A fragmentação eleva custo de triagem, alonga o tempo até a decisão e reduz a qualidade da evidência.

Visão do produto. Tornar decisões de investimento social mais acessíveis, explicáveis e acompanháveis, conectando objetivos institucionais a iniciativas executáveis e evidências proporcionais ao risco.

Proposta de valor. Para o financiador: menor esforço administrativo, trilha auditável e visão comparável do pipeline. Para a OSC: cadastro reutilizável, checklist claro e menos retrabalho. Para o ecossistema: taxonomia compartilhada e dados agregados, anonimizados e governados.

USP a testar. “Do edital ao resultado, um workflow de investimento social que transforma critérios, diligência e evidências em decisões rastreáveis — com oportunidades estruturadas para o Brasil.” Não prometer “melhor impacto” por meio de score.

Posicionamento. Infraestrutura de gestão e evidência para investimento social corporativo e grants. Marketplace é canal de descoberta, não o negócio central no primeiro estágio. API, white-label, analytics vendidos separadamente e pagamentos não são prioridades do MVP.

Clientes, usuários e trabalhos a realizar

Perfil	Papel econômico	Necessidade principal	Produto inicial
Empresa média/grande com programa recorrente	Comprador/pagador	Organizar carteira, aprovação e relatórios	SaaS anual com gestão de programas
Instituto ou fundação empresarial	Comprador/pagador e gestor	Selecionar e monitorar grants com governança	Grants lifecycle, revisão e evidências
Analista de investimento social/ESG	Usuário diário	Comparar propostas, cobrar documentos e acompanhar metas	Inbox de triagem, score explicado, tarefas
Compliance, jurídico, fiscal e compras	Aprovador/revisor	Identificar bloqueios e preservar justificativa	Checklist, regras, revisão e trilha de auditoria
Gestor de OSC	Usuário frequente, não pagador inicial	Preparar oportunidade e comprovar execução	Portal guiado, documentos reutilizáveis e alertas
Contador/consultoria especializada	Parceiro eventual	Conferir informações e apoiar cliente	Acesso delegado e exportação, sem autoridade para decisão da plataforma
Beneficiário final	Beneficiário, não usuário padrão	Receber serviço/benefício e proteção adequada	Não criar conta individual no MVP sem necessidade clara

Jobs to be done. O financiador precisa: definir chamadas e critérios; encontrar candidaturas elegíveis; comparar sem perder contexto; documentar conflito e aprovação; acompanhar recursos e resultados; produzir relatórios reproduzíveis. A OSC precisa: entender se pode concorrer; responder uma vez às perguntas básicas; anexar evidências legíveis; saber o que está pendente; reportar mudanças e resultados com baixo custo.

ICP inicial. Empresas, institutos e fundações com ao menos dois ciclos/programas por ano, equipe responsável identificável e necessidade de prestar contas a liderança, conselho ou parceiros. Preferir um setor/território onde o patrocinador fundador já tenha relações. Evitar no início clientes que só queiram uma lista ampla de ONGs, um cálculo de incentivo fiscal sem consultor, ou uma plataforma de doação individual em massa.

Concorrência e substitutos

A comparação abaixo deve distinguir concorrentes diretos de referências adjacentes. “Não divulgado” é preferível a inferir preço ou stack. Vários fornecedores resolvem gestão de grants, doação empresarial, voluntariado, crowdfunding ou incentivos; isso não demonstra que qualquer um tenha exatamente o mesmo escopo.

Plataforma	Mercado/função observável	Categoria	O que aprender / não copiar
Prosas	Brasil; divulgação e administração de editais, inscrições, seleção e monitoramento de iniciativas de impacto; declara rede de mais de 150 mil empreendedores sociais	Concorrente direto em edital e workflow	Aprender com seleção, formulários, avaliadores e acompanhamento; diferenciar com perfil reutilizável, trilha pós-aporte e explicabilidade integrada. [4]
Incentiv.me	Brasil; hub/plataforma de investimento de impacto, com patrocínios, doações, incentivos e suporte especializado a captação	Direto/adjacente em captação e incentivo	O serviço assistido é parte do produto; não reduzir incentivo fiscal a campo automático nem depender de intermediação opaca. [5]
Benevity	Global; plataforma empresarial modular para doação, grants, voluntariado e engajamento; preço personalizado por módulos e escala	Benchmark enterprise	Aprender com plataforma unificada, diligência e reporting; não competir de início em escala global, pagamentos multinacionais ou base internacional. [6]
Submittable	Global; gestão de CSR, grants e candidaturas, com revisão, tracking financeiro, segurança, relatórios e opções enterprise	Concorrente/benchmark de workflow	Benchmark de gestão de ciclo de grant; validar localização, integrações e adequação ao Brasil antes de qualquer comparação de preço. [7]
Good Grants	Global; gestão do ciclo de grants, formulários, triagem, revisão, resultados e pós-award; anuncia planos sem cobrança percentual de desembolso	Benchmark funcional	Aprender com configuração de programas e tarifas não vinculadas ao valor distribuído; competir pela camada contextual brasileira e integração de evidências. [8]
Benfeitoria	Brasil; financiamento coletivo para causas e projetos	Substituto/adjacente	Campanhas são adequadas a captação pública; não substituem governança de portfólio corporativo nem diligência de grants. [9]
Doare	Brasil; ferramentas de doação digital para organizações	Adjacente	Pode ser integração futura para doações; não construir processamento de pagamentos próprio no MVP. [10]
Blackbaud YourCause	Global; filantropia corporativa/engajamento de funcionários	Benchmark/adjacente	Observar integração com programas de empresa; validar disponibilidade e localização brasileira. [11]
Goodera	Global; programas de voluntariado corporativo e experiências de impacto	Adjacente	Voluntariado é um módulo futuro, não requisito para provar o primeiro workflow financiador-OSC. [12]
B1G1	Global; modelo de “giving” associado a atividades empresariais	Substituto/adjacente	Microcontribuição pode gerar engajamento, mas difere de governança e financiamento de grants. [13]

Clientes, modelo comercial e aquisição

Plataforma	Cliente-alvo e posição	Modelo/preço público e rota de aquisição observada
Prosas	Empresas, institutos/fundações e setor público; OSCs/proponentes têm cadastro e submissões gratuitos. Direto em editais e gestão de parcerias.	Vende publicação/gestão e serviços ao patrocinador; preço do core por cotação. Central de Editais e newsletter abastecem oferta; venda/assessoria para patrocinadores. O Programa de Dados aparece separado do core. [4] [44]
Incentiv.me	Empresas que investem via leis de incentivo; OSCs/proponentes e projetos incentivados. Direto nessa vertical.	Cadastro de projeto gratuito; captação declarada no sucesso e serviços estratégicos/operacionais por contratação específica; sem tabela completa de preços. Aquisição consultiva pela plataforma e pelos serviços de estruturação/captação. [5]
Benfeitoria	Realizadores de campanhas e benfeitores; crowdfunding/recorrência. Substituto na captação pública, não no grant management.	Comissão opcional ("livre"); tarifas de pagamento variam conforme integradora. Entrada por campanha self-service, curadoria em modalidades específicas, comunidade e canais de parceiros. [9] [50]
Doare	OSCs, hospitais e instituições filantrópicas; checkout, doação recorrente e CRM. Adjacente como infraestrutura.	SaaS + taxa de transação: Basic R\$390/mês, Professional R\$650/mês, Advanced R\$980/mês, além das taxas por método; Enterprise sob consulta. Página de planos pública favorece comparação direta. [10] [45]
Benevity	Grandes empresas/multinacionais; giving, grants, voluntariado e compliance global.	Preço modular sob cotação, baseado em módulos, empregados, países, volume de desembolso e compliance. Entrada por demonstração/venda enterprise; nonprofits podem se registrar gratuitamente. [6] [48]
Blackbaud YourCause	Empresas e equipes de CSR/grants; suite de giving, voluntariado, grants e reporting.	Sem tabela de YourCause; cotação baseada em porte, usuários, módulos, suporte/serviços; implementação/treinamento normalmente incluídos. Rota de aquisição por demo e venda enterprise. [11] [49]
Goodera	Empresas que contratam programas de voluntariado corporativo gerenciados; OSCs participam como parceiras.	Preço corporativo atual não divulgado; OSCs sem taxa de plataforma/assinatura. Rota de venda consultiva de programas com curadoria, coordenação e operação. Valor de US\$25–50 por placement é histórico (2022), não preço vigente. [12]
Submittable	Fundações, OSCs, empresas e setor público que operam aplicações/grants. Direto no back-office.	Venda SaaS por demo/cotação; AWS Marketplace lista Professional a US\$22.500/ano e Premium a US\$47.500/ano em pacotes/canal específicos; não generalizar como preço universal. [7] [46]

Plataforma	Cliente-alvo e posição	Modelo/preço público e rota de aquisição observada
Good Grants	Grantmakers e programas de bolsas/grants; gestão configurável do ciclo completo.	Planos públicos anuais: Intro AUD 5.350 e Premium AUD 10.700; até 10 mil candidaturas nesses planos. Teste e compra direta; Enterprise sob cotação para maior volume/serviços customizados. [8]
B1G1	PMEs e negócios que convertem eventos/atividades em microimpactos; catálogo de projetos curados.	Membership separado da contribuição: planos públicos de US\$33, US\$66 e US\$132/mês (ou US\$365, US\$730 e US\$1.460/ano); opção maior sob consulta. Onboarding/membership direto; custos de processamento não são receita de doação. [13] [47]

Pegada pública, tecnologia e lacunas

Plataforma	Escala/sinais publicados	Tecnologia/integrabilidade divulgada; o que permanece não divulgado
Prosas	Contadores variam por página: mais de 150 mil empreendedores, 250–300 mil usuários, 1.800–3.000 editais e 240–380 mil propostas. Não são uma série auditada/comparável.	Web, formulários configuráveis, pesos, workflow, dashboard e resumos de editais por IA; stack, API pública, SLA, certificações, métricas/revisão da IA não divulgados. [4]
Incentiv.me	A plataforma diz ter 6 mil+ projetos; contagens são claims e não revelam equipe ou receita.	Matching/recomendação, filtros, due diligence, cálculo de potencial e monitoramento são descritos; infraestrutura, API, stack, modelo/avaliação de IA e segurança técnica não divulgados. [5]
Benfeitoria	Declara 15 mil+ projetos, R\$660 milhões arrecadados e 570 mil+ apoiadores; escopo e período não são metodologia auditada.	Checkout e integradores de pagamento são documentados; não publica stack, API, algoritmo de matching ou arquitetura. [9]
Doare	Site declara cerca de 4.400–4.500 organizações; fonte e data diferem. Não confundir adoção com tamanho da empresa.	Declara AWS/autoscaling, API REST, integrações e IA antifraude; detalhes de stack, região, certificações, SLA e modelo IA não divulgados. [10]
Benevity	Foco enterprise; fornecedor declara rede global de milhões de nonprofits. Valores de rede não equivalem a clientes/funcionários.	Publica APIs REST/OpenAPI, exportação, SSO, integrações e controles/certificações; infraestrutura AWS e residência nos EUA são declaradas. IA aparece como AI-native, sem modelo divulgado. [6] [52]
Blackbaud YourCause	Produto global; divulga 170+ moedas e rede de milhões de nonprofits como claims do fornecedor.	CSRconnect/GrantsConnect, SSO, reporting assistido por IA e controles corporativos são descritos; stack/API pública e detalhes do modelo não divulgados. [11]
Goodera	Site declara 500+ empresas e 50K+ organizações parceiras; fonte/corte variam por página.	Integração via WhatsApp/Infobip e sincronização com Benevity documentadas; API é específica a essa integração. Stack, SLA e IA/matching técnico não divulgados. [12] [51]

Plataforma	Escala/sinais publicados	Tecnologia/integrabilidade divulgada; o que permanece não divulgado
Submittable	Não foi localizada escala pública homogênea de candidaturas/clientes que possa ser comparada.	Divulga SaaS, SAML SSO, permissões, SOC 2/HIPAA e Stripe; stack, região, APIs, SLA e matching fora do grant workflow não divulgados. [7]
Good Grants	Não apresenta um indicador público comparável de base de clientes na fonte consultada.	Divulga AWS, VPC, MFA, residência regional, ISO 27001, SOC 2, API/webhooks, Zapier/Make/Salesforce e SSO. Linguagem, banco de dados e tecnologia/avaliação da IA não divulgados. [8] [53]
B1G1	Fonte independente reportou quase 3 mil empresas em mais de 40 países em 2021; é retrato histórico, não escala atual confirmada.	Divulga Zapier e API limitada para carrinho/Stories; stack, SLA, API completa, certificações e mecanismos de matching não divulgados. [13]

Limite de comparação: os sites publicam números com denominadores diferentes — OSCs, projetos, usuários, funcionários, campanhas, transações e países. Nenhum número foi tratado como faturamento, headcount da empresa ou prova independente de impacto. Não foi encontrada informação pública comparável de receita/equipe da maioria dos fornecedores; por isso, comparamos pegada de produto e rede, não “tamanho da empresa”. “Não divulgado” descreve a documentação encontrada e não prova ausência de capacidade.

Implicações competitivas. Editais, coleta de candidaturas, filtros, avaliações, grants e relatórios já são funções estabelecidas. Não se deve lançar outra plataforma horizontal de “impacto” sem distribuição. A oportunidade está em: (1) cadastro de OSC que reduz retrabalho sem alegar validação oficial; (2) política de evidências e compliance configurável; (3) regras fiscais versionadas e separadas do score, com fonte e revisão profissional; (4) experiência para pequena OSC; (5) integração/exportação para sistemas corporativos, contábeis e públicos, conforme demanda comprovada.

Moat defensável. Não será um peso secreto do algoritmo. Será o histórico estruturado de oportunidades, critérios e decisões; metadados de completude e validade documental; desempenho observado e evidências longitudinais; taxonomias locais; conexões e custos de troca legítimos via workflow. A marca e a confiança dependerão de corrigir erros, permitir contestação e não vender rótulos de risco como fatos.

MVP e experiência de produto

MVP financiador: organização/tenant; programa e chamada; critérios versionados; pipeline de candidaturas; formulário configurável simples; triagem com hard blockers; distribuição de pareceristas; conflito de interesse e abstenção; decisão/aprovação; tarefas e prazos; registro de compromisso financeiro (sem movimentar recursos); cronograma; uploads privados; indicadores básicos; relatório exportável; logs.

MVP OSC: perfil institucional; uma oportunidade/projeto; causa e território; orçamento com rubricas simples; metas e evidências; documentos com validade e estado de revisão; modo

de rascunho; status da submissão; solicitações de complemento; alertas e exportação. O sistema deve dizer “informação autodeclarada” versus “verificada por fonte externa” versus “revisada por pessoa”. Não exigir vídeo/foto para todos os casos.

Necessidades fracionadas. Manter um projeto-mãe e permitir linhas/tranches financiáveis, cada qual com valor mínimo/meta, prazo, escopo, orçamento e marco vinculado. O total prometido não pode exceder o orçamento elegível; mostrar se a tranche é independente ou complementar, compromissos pendentes e saldo do projeto. Evidências podem ser compartilhadas ou específicas por tranche. Não inferir que o fracionamento torna uma parcela elegível a incentivo fiscal: a aprovação é do projeto e das regras aplicáveis.

Experiência de descoberta: substituir swipe por uma lista pesquisável e shortlist comparável. Cada item deve exibir compatibilidade, motivos favoráveis, restrições, lacunas de dados, validade documental e próxima ação. A empresa salva, solicita esclarecimento, compartilha internamente e envia a aprovação. Só liberar “demonstrar interesse” quando houver capacidade real de contato e regras claras para evitar falsas expectativas.

Não incluir no MVP: app nativo iOS/Android; pagamento/custódia/split; scoring automatizado de pessoas/beneficiários; selo de impacto; classificação pública de OSCs; blockchain; OCR para qualquer tipo de documento sem fluxo de revisão; IA autônoma de recomendação fiscal; analytics comparativo de clientes; voluntariado; APIs públicas sem modelo de autorização; suporte a múltiplos países/moedas na interface; recomendações públicas virais.

Critério para lançar o piloto. Um comprador âncora paga ou assina carta de intenção qualificada com orçamento, fornece critérios e nomeia revisor. Mínimo operacional recomendado: 5–10 oportunidades reais, 3–5 OSCs por programa e revisão humana de todos os casos. A hipótese de três OSCs do briefing serve para teste de protótipo e onboarding, não para inferir taxa de conversão ou qualidade de recomendação.

Rede de prestadores e acompanhamento articulado

O produto pode criar trabalho para profissionais e fornecedores e reduzir a lacuna de capacidade de uma OSC sem se tornar empregador, conselho profissional, certificador ou custodiante de pagamento. O serviço é descoberto e contratado **no contexto do projeto específico de cada OSC**: projeto → necessidade → escopo/entregável → prestador → evidência/aceite. Assim, um perfil profissional não dá acesso geral a todas as iniciativas da OSC nem cria um marketplace desvinculado do trabalho financiado. Contadores, consultorias, psicólogos, transportadores e outros profissionais podem colaborar sob contrato/mandato das partes; a plataforma estrutura e controla o workflow, enquanto a contratação e a responsabilidade técnica continuam com as partes, após revisão jurídica do caso.

Diretório estruturado e pesquisável. Perfil facultativo, revisável pelo prestador: serviços e entregáveis; situações/necessidades que costuma atender; áreas e territórios; presencial/remoto; capacidade e disponibilidade; faixa de preço/forma de contratação; acessibilidade; idiomas; referências autorizadas; CNPJ/identidade profissional; licenças ou registros obrigatórios, órgão emissor, escopo e data de consulta. A taxonomia pode incluir contabilidade e prestação de contas, auditoria, jurídico, captação e desenvolvimento institucional, avaliação/indicadores, psicologia e apoio psicossocial, transporte/logística, acessibilidade/interpretação, alimentação, tecnologia e comunicação. Cada campo recebe estado “autodeclarado”, “documento apresentado” ou “verificação externa com fonte/data”; nenhum deles é um selo geral de qualidade. O usuário pesquisa por tipo de serviço, necessidade do projeto, território, prazo, idioma, acessibilidade e requisito objetivo. Não usar diagnóstico, raça, religião ou vulnerabilidade individual como atalho de elegibilidade do prestador ou beneficiário.

Fluxo de trabalho. A OSC ou empresa cria uma demanda e define escopo, orçamento, entregável, prazo, critério de seleção e responsáveis. Prestadores opt-in demonstram interesse ou recebem convite; o contratante compara propostas, registra justificativa/conflito, seleciona e formaliza contrato diretamente. A execução acompanha tarefas, marcos, mensagens/comentários, pendências, documentos, pareceres, notas/recibos quando pertinentes, evidências, versão, autor e aceite. Alertas em tempo real e histórico assíncrono coexistem; cada ação relevante é datada, exportável e vinculada ao projeto/marco. No MVP, não há folha de pagamento, split, retenção, liberação nem repasse financeiro pela plataforma.

Fronteira entre IA e responsabilidade profissional. A IA estrutura o projeto e a necessidade; sugere a categoria/ordem de trabalho; cria e roteia tarefas; cobra prazos; indica campos ausentes, validade documental e possível inconsistência; mantém status, lembretes, histórico e evidências organizados. Pode preparar uma minuta com fontes/citações, sempre identificada como rascunho assistido. **Relatórios, documentos técnicos, recibos/pareceres e evidências substantivas são inseridos, revisados, assumidos e assinados pelo profissional responsável**, que informa escopo de atuação e credencial quando aplicável. A IA não escreve a conclusão como fato, não substitui o juízo técnico e nunca assina ou aprova em nome do profissional. A autoria não pode ser compartilhada por conta ou inferida de uma aprovação automatizada.

O registro da assinatura preserva arquivo/versão exata, identidade autenticada, papel e credencial declarados/verificados, data/hora, método e trilha de alterações; correção gera nova versão sem apagar o histórico. A assinatura eletrônica adequada depende do documento, das partes e do destinatário; interações com órgãos públicos devem observar o regime e nível exigido para aquele ato, e demais contratos/pareceres precisam de análise jurídica própria. A plataforma pode integrar um provedor de assinatura, mas não declara por conta própria que qualquer clique satisfaz todo requisito legal. [43]

Papel	Acesso padrão e visibilidade
OSC contratante	Convida o profissional a uma OSC/projeto/marco; controla se ele pode ver, enviar ou apenas comentar; revoga acesso e acompanha tarefas, pareceres e evidências.
Empresa/financiador	Acompanha status, entregáveis e evidência que pertencem ao programa financiado e para os quais recebeu autorização; não vê automaticamente prontuários, dados pessoais de beneficiários ou pastas de outros clientes.
Prestador	Vê somente a solicitação aceita/atribuída, os dados mínimos necessários e documentos explicitamente compartilhados; envia seu trabalho e registra autoria; não consulta outras OSCs, empresas ou candidaturas.
Governo/gestor de parceria pública	Acesso institucional apenas quando houver instrumento, finalidade, competência e autorização formal; limitado aos campos e documentos exigidos para aquela prestação de contas. Não recebe acesso global por ser usuário governamental.
Interesse público	Relatórios públicos mostram dados publicados pelo responsável ou agregados com limiar de privacidade; não expõem due diligence, contrato privado, parecer protegido, documentos pessoais nem dados de saúde.

Princípios éticos, legais e de trabalho. Aplicar dignidade, igualdade e não discriminação; filtros têm de ser objetivos, ligados à tarefa e explicados. Não ranquear por raça, religião, opinião política, saúde, deficiência ou outra característica sensível; não inferir vulnerabilidade individual para selecionar quem recebe serviço. A relação de consumo, a prestação profissional regulada, os deveres de contratante e eventual vínculo trabalhista dependem dos fatos e da lei; não são afastados pelo rótulo “freelancer” ou pelos termos da plataforma. Exigir credencial/registro somente quando a atividade legalmente exigir e verificar escopo/validade em fonte competente. Dados sensíveis (por exemplo, dados de saúde e notas psicológicas) ficam fora do diretório e do dossiê geral; qualquer tratamento necessário exige finalidade, acesso segregado, base legal e retenção definidos com especialista. [40] [41] [42]

Não criar listas negras nem exclusões automáticas por denúncia, nota, sinal incompleto ou score opaco. Separar reclamação de fato verificado, registrar prova/origem/data, oferecer resposta, correção e revisão humana. Feedback não é publicado automaticamente; ranking não pode ser comprado e pagamento não melhora posição. A plataforma deve oferecer trilha de conflitos e possível favorecimento, política anticorrupção e critérios de seleção claros; Código de Defesa do Consumidor, Constituição, normas profissionais e legislação trabalhista se aplicam conforme a relação concreta, com validação jurídica.

Faseamento recomendado. Piloto: colaboração por convite e catálogo privado/semiaberto, opt-in, em poucos serviços do comprador âncora, com contrato direto e permissões por projeto. Próxima fase: diretório pesquisável mais amplo somente depois de governança de credenciais/fontes, processo de reclamação, privacidade, termos de intermediação e testes de viés. Não publicar “regular”, “confiável” ou “ético” como certificação geral. Métricas: tempo para preencher uma necessidade, resposta/entrega no prazo, completude da

evidência, satisfação de cada lado, contestação/falso positivo e distribuição territorial — não número de prestadores como proxy de qualidade.

Motor de compatibilidade — especificação inicial

Separar quatro saídas: **elegibilidade, compatibilidade, confiança dos dados e recomendação operacional**. O score não deve fundir esses conceitos.

1. **Hard blockers:** regra legal explicitamente verificada; chamada encerrada; território incompatível se obrigatório; entidade fora da definição elegível; valor fora do intervalo não negociável; conflito não resolvido; sanção/impedimento confirmado por fonte e política aprovada; documento obrigatório inválido quando a regra exigir. Um bloqueio precisa registrar regra, versão, evidência, data e origem. Um sinal incerto vira revisão humana, não bloqueio definitivo.
2. **Soft criteria, pontuação 0–100:** alinhamento de causa/objetivo 20; cobertura territorial 15; compatibilidade de orçamento/ticket 15; alinhamento de mecanismo/programa (quando aplicável) 15; capacidade e prontidão 10; evidência/indicadores 10; perfil e preferência do financiador 5; cronograma/urgência 5; risco operacional residual 5. Pesos são hipótese inicial a calibrar com decisões reais e revisão de viés. “Compliance” obrigatório é porta de entrada; não deve ser compensado por afinidade.
3. **Confiança separada:** percentagem de campos críticos apoiados por evidência vigente e origem de cada campo. Documento ausente reduz confiança e pode pedir informação; não deve ser confundido com baixo impacto social.
4. **Explicação:** exibir 2–3 fatores que elevaram o resultado, 1–3 lacunas e como alterar a compatibilidade. Nunca exibir uma porcentagem sem revelar critério, pesos relevantes, versão e data.
5. **Estados:** recomendação prioritária, compatível, potencial com lacunas, revisão humana, inelegível/bloqueado. No início, o sistema ordena apenas dentro do programa configurado; a decisão final é humana.

Fórmula inicial: score de compatibilidade = soma dos pesos aplicáveis × nota normalizada de cada critério × fator de evidência explícito. Arredondar para inteiro apenas na interface. Se dado obrigatório estiver ausente, apresentar intervalo ou estado “dados insuficientes”, não nota fictícia. Manter um conjunto de referência sintético e um conjunto consentido/de-identificado para regressão; comparar recomendações com as decisões justificadas dos avaliadores. Não otimizar “conversão” sacrificando elegibilidade, equidade territorial ou política do financiador.

Por que os pesos propostos originalmente não servem ainda. Um peso fiscal de 35% dá aparência de certeza, concentra o modelo em regras que variam por incentivo, local e exercício e pode tratar como equivalentes mecanismos que não são. Compliance não é afinidade. Causa/território e orçamento também dependem de escolha da empresa e edital. Começar por configuração de critérios por programa e revisão de peso com clientes, sem otimização automática. O mecanismo fiscal só entra como filtro determinístico quando a fonte oficial, o ano-calendário, o contribuinte e a elegibilidade do projeto foram confirmados.

Inteligência fiscal — motor separado e cauteloso

A Lei de Incentivo à Cultura não é benefício genérico para qualquer causa: é restrita a projeto cultural aprovado e a contribuinte elegível. A página do Ministério da Cultura descreve limites gerais de dedução federal de até 4% do IR devido para pessoa jurídica e 6% para pessoa física, mas os detalhes dependem de enquadramento, modalidade, aprovação, limite individual/global e regra vigente; o sistema deve encaminhar ao mecanismo e ao especialista, não prometer retorno tributário. A IN MinC 29/2026 trata de apresentação, acompanhamento, prestação de contas e avaliação; por exemplo, disciplina contas específicas, liberação e movimentação formal dos recursos. [14] [15] [16]

A regra do incentivo ao esporte mudou materialmente: a Lei Complementar 222/2025 revogou a Lei 11.438/2006. A LC prevê limite federal geral para pessoa jurídica de 3%, com regra transitória de 2% até o ano-calendário de 2027; prevê 4% para projetos de inclusão social por esporte em combinação com outros incentivos especificados. A própria lei prevê limites anuais fixados pelo Executivo e exige projeto aprovado e recursos em conta bancária específica. Portanto, regras legadas não podem permanecer hardcoded. A página da lei antiga está marcada como revogada e não deve ser usada como autoridade vigente. [17] [18]

Outros mecanismos merecem cadastro separado, mas não formam um “crédito fiscal social” genérico:

Mecanismo	Requisitos/limites gerais verificados	Tratamento recomendado no produto
Fundos dos Direitos da Criança e do Adolescente (FIA/FMDCA)	Pessoa jurídica no lucro real pode deduzir até 1% do IR devido, em doação a fundo controlado pelo conselho e conforme os requisitos do ECA; a lei trata essa dedução separadamente. Não equivale a doação direta dedutível a qualquer OSC.	Registrar fundo/ente, comprovante, período e regra; não apresentar chamada de uma OSC como elegível automaticamente. [38]
Fundos da Pessoa Idosa	Pessoa jurídica pode deduzir do IR devido doações comprovadas a fundos habilitados, com limite legal de 1%; pessoa física tem regras/limites e fluxo próprios.	Separar fundo, conselho, ente, regime, comprovante e fluxo. Não misturar limites de PF e PJ nem somar mecanismos sem base. [39]
Pronon e Pronas/PCD	Pessoa jurídica no lucro real; limite legal de 1% por programa, em projetos/ações previamente aprovados. A lei federal passou a admitir deduções empresariais até 2031; limites globais anuais são fixados pelo Executivo. Instituições precisam atender qualificações e submeter propostas no cronograma anual do Ministério da Saúde/Transferegov.	Fonte/ano/ato de aprovação e habilitação da instituição são hard requirements. Verificar edital e teto do exercício antes de qualquer orientação. Não classificar toda OSC de saúde como elegível. [36] [37]

Mecanismo	Requisitos/limites gerais verificados	Tratamento recomendado no produto
Audiovisual e reciclagem	A Receita Federal lista ambos entre deduções incentivadas de pessoa física; os mecanismos dependem de aprovação/credenciamento, forma de investimento e lei própria. Regras corporativas exigem matriz independente e checagem da norma vigente.	Manter fora do MVP fiscal automatizado; encaminhar para especialista até validar regime, beneficiário, projeto, teto e comprovação para PJ. [35]

Para pessoa física, a Receita lista ainda doações a fundos, Cultura, Audiovisual, reciclagem, Esporte, Pronon e Pronas/PCD, com limites e condições próprios; esses quadros da declaração não são a matriz fiscal de pessoa jurídica. A regra e o fluxo diferem por contribuinte, fundo/ente, período, aprovação e forma da destinação. [19] [35]

Componente do fiscal rule engine	Requisito
Registro da regra	jurisdição, mecanismo, contribuinte, beneficiário, programa, artigo, modalidade, percentuais/limites, condições, vigência, revogação e transição
Fonte	URL oficial, trecho/ato, data de consulta, responsável técnico e anexos aplicáveis
Versão	pacote imutável, por exemplo `BR-FED-SPORT-2026.01`, data de entrada/saída e regras anteriores preservadas
Resultado	pré-checagem informativa com hipótese e lacunas, nunca cálculo/parecer definitivo
Controles	revisão de especialista, dupla aprovação para publicar, testes de regressão, alerta antes de vencer regra
Responsabilidade	avisos contextuais; contrato e interface distinguem ferramenta de informação de consultoria tributária

No MVP, limitar o módulo fiscal a “possível mecanismo a validar”, links oficiais e checklist. Não calcular economia fiscal efetiva nem alegar dedutibilidade. Uma pessoa revisora aprova conteúdo e a empresa/contador confirma a situação do contribuinte. Incorporar mudanças regulatórias só depois de parecer documentado. Essa cautela é produto e gestão de risco, não uma opinião legal.

Modelo de negócio e preço a validar

Oferta hipotética	Escopo	Faixa de teste (não é preço de concorrente nem promessa comercial)
Piloto pago, 8–12 semanas	1 programa, onboarding, até 10 organizações, acompanhamento e relatório final	R\$ 18 mil–36 mil por piloto
SaaS Essencial	até 2 programas/ano, gestão de pipeline e relatórios básicos	R\$ 36 mil–72 mil/ano
SaaS Enterprise	múltiplos programas, governança, SSO, exportação e suporte acordado	R\$ 96 mil–240 mil/ano, a validar por escopo

Oferta hipotética	Escopo	Faixa de teste (não é preço de concorrente nem promessa comercial)
Implantação	configuração de workflow, importação e treinamento	R\$ 8 mil–30 mil, dependendo de legado e integrações
OSC	perfil e submissão	gratuito no início; premium só se houver benefício claro e demanda comprovada

Modelos de negócio avaliados

Modelo	Papel possível	Decisão
SaaS B2B	Receita recorrente pelo workflow e governança	Principal motor de receita no início.
Marketplace com comissão	Receita atrelada a cada aporte ou match	Adiar: incentiva volume em vez de qualidade e traz questões de conflito, pagamentos e atribuição.
Rede de serviços por projeto	Busca, contratação direta, escopo e acompanhamento de prestadores que apoiem uma OSC em um projeto específico	Valor principal no SaaS do financiador/OSC; catálogo opt-in e privado no piloto. Sem cobrar por posição, vender “selos” ou receber pagamentos. Comissões/leads somente após análise jurídica, competição e conflito.
Freemium para OSC	Cadastro/submissão gratuitos e ferramentas avançadas pagas	Manter cadastro e aplicação gratuitos; não cobrar OSC antes de comprovar valor e capacidade de pagamento.
Enterprise	Licença, suporte, segurança e integração sob contrato	Caminho para grandes contas após produto repetível, controles e SLA.
White-label	Plataforma com marca de grupo empresarial/fundação	Somente quando houver 2+ clientes pedindo padrão similar e manutenção centralizada.
API / dados	Vender dados/inteligência de matching ou compliance	Fase posterior; governança, qualidade, base legal, segurança e disponibilidade precisam estar comprovadas. Dados pessoais não serão produto.
Data / analytics agregados	Relatórios de demanda territorial, causas, tempos e faixas de aporte	Fase posterior; somente agregados com controle de reidentificação, finalidade e contrato; não vender dados de OSC/beneficiários nem inferir causalidade de impacto.
Serviços	Curadoria, treinamento e implantação	Usar de forma limitada para ativar piloto e aprender; separar escopo e preço de licença. Evitar virar consultoria sem margem escalável.

Modelo recomendado: SaaS anual por empresa/programa, com implantação faturada separadamente. Cobrar por assentos ou volume de submissões só quando não prejudicar a colaboração nem criar incentivo à exclusão de OSCs. Evitar comissão sobre aporte: pode parecer conflito de interesses, dificultar a percepção de independência e acoplar receita a fluxos financeiros/regulatórios. Se futuramente houver pagamentos, gateway e regras

contratuais próprias; não reter fundos. White-label e API só após casos de uso pagos e repetidos.

Unidade econômica a medir, não presumir: ACV = receita recorrente anual por conta; margem bruta = receita menos cloud, suporte, processamento e custo de verificação por conta; CAC = vendas e marketing atribuíveis por novo cliente; payback = CAC / lucro bruto mensal da conta; churn e expansão por coorte; LTV só quando houver coortes observadas por tempo suficiente. Metas internas iniciais: margem bruta >70% após estabilização; payback do CAC <12 meses; retenção bruta anual >85% antes de escalar aquisição. Não publicar CAC/LTV estimados como fatos. Exemplo aritmético ilustrativo: ACV de R\$72 mil e margem de 75% representam R\$54 mil de contribuição bruta anual; com CAC hipotético de R\$36 mil, payback simples seria 8 meses. Os dois preços/valores são hipóteses para teste, não dados observados.

Go-to-market e validação de product-market fit

Venda fundadora, serviço assistido. Identificar 20–30 contas de ICP em uma região/indústria com relação existente. Entrevistar quem administra programas e quem aprova orçamento. Propor piloto pago a 3–5 contas qualificadas. Um comprador âncora deve co-desenhar critérios e fornecer um programa verdadeiro. Usar consultoria leve apenas para onboarding e curadoria; registrar tudo que é serviço manual para decidir o que automatizar.

Aquisição das OSCs. Começar por indicação do patrocinador, redes territoriais, Prosas/edital aberto quando pertinente, conselhos/comunidades e contadores/consultorias. Dar orientação prática e reduzir documentos duplicados. Não importar nem publicar perfis pessoais sem uma finalidade/base legal e consentimento apropriado; respeitar políticas de app stores quanto a dados obtidos de terceiros. [20]

Aquisição de prestadores. Começar com profissionais indicados pela OSC ou comprador âncora, por projeto e necessidade concreta, convidando-os a um perfil opt-in e a demonstrar credenciais/escopo. Não afirmar parceria ou endosso de conselhos profissionais sem acordo explícito. Medir cobertura por território/categoria, tempo para encontrar prestador e proporção de perfis com campos de verificação atualizados; abrir catálogo público somente após controles e política de contestação.

Experimentos de 90 dias: disposição a pagar por workflow (não por “IA”); tempo da empresa para montar shortlist; percentagem das candidaturas com documentos obrigatórios completos; tempo de resposta da OSC; decisões que exigiram revisão fiscal/legal; taxa de projetos que chegam à primeira entrega; retrabalho por relatório; confiança dos dois lados. Uma métrica de match só vale após avaliadores explicarem decisões e haver amostra suficiente.

Hipóteses de validação:

- Um comprador paga por reduzir operação e melhorar rastreabilidade mesmo sem promessa de benefício fiscal.
- A OSC aceita fornecer dados se puder reutilizar perfil e enxergar oportunidades reais.
- O comprador prefere lista explicada e workflow de aprovação a swipe.
- Templates e reuso de evidências reduzem pelo menos um passo ou ciclo de coleta, sem diminuir controle.
- Regras fiscais localizadas aumentam utilidade somente após governança e revisão especializada.

Arquitetura de referência

Flutter, React Native ou PWA?

Opção	Vantagens	Custos/riscos no caso de uso	Recomendação
PWA/web responsiva	Uma aplicação para desktop e celular; link de convite, implantação e atualização simples; baixa barreira para OSC	Capacidades offline/push/câmera dependem do navegador e sistema; experiência de loja e algumas integrações nativas são limitadas	Escolha para MVP e piloto; garantir upload móvel e modo de rascunho resiliente.
React Native	Compartilha conhecimento TypeScript/React; acesso a recursos nativos	Build, assinatura, revisão de loja e compatibilidade de SDKs aumentam esforço; não resolve sozinho a necessidade de painel desktop	Considerar depois se houver uso frequente de câmera/notificação/offline que justifique app.
Flutter	UI consistente e bom suporte a builds multiplataforma	Nova linguagem/ecossistema se o backend/web usar TypeScript; ainda exige operação de lojas e duplicação de fluxos de gestão	Não escolher antes de demonstrar vantagem em uso de campo; não é requisito de arquitetura do produto.

Camada	Decisão recomendada	Justificativa / evolução
Interface	Aplicação web responsiva em React/TypeScript; PWA opcional	Desktop é central ao trabalho de empresa; celular facilita cadastro e evidência de campo. Adiar nativo e validar aquisição/uso primeiro.
API	TypeScript/NestJS ou framework equivalente, REST versionada e OpenAPI	Estrutura modular e tipagem; separar domínio de regras fiscais, grants, identidade e evidências. Escolha final após equipe.
Dados	PostgreSQL gerenciado	Transações, relações e filtros suficientes no MVP; multi-tenant por tenant_id e autorização em cada objeto; RLS como defesa adicional testada.
Busca	PostgreSQL full-text + filtros	Adiar OpenSearch/Elastic até volume e relevância justificarem operação extra.
Arquivos	S3-compatible privado com KMS/chave gerenciada, URLs assinadas curtas, antivírus e versionamento	Documentos têm alta sensibilidade operacional; metadados no banco, conteúdo fora do banco.

Camada	Decisão recomendada	Justificativa / evolução
Processamento	Jobs/filas gerenciadas para OCR, e-mail, relatórios e notificações	Fila só para trabalho assíncrono; Redis não é dependência obrigatória antes de medição.
IA	Gateway interno por interface de provider; política de não retenção/treinamento contratual quando possível	Trocar fornecedor sem reescrever domínio; limites, logging, avaliação, redaction e custos por função.
Identidade	OIDC; MFA para funções de alto privilégio; convite por organização	RBAC por papel mais ABAC por organização, programa, documento e estado. Passkeys como evolução, não bloqueio de MVP.
Infra	Cloud gerenciada com IaC, ambientes isolados, segredos em vault, CI/CD e backups testados	Evita lock-in em serviço de domínio; exportação de dados e cópias independentes.
Observabilidade	Logs estruturados, métricas, tracing e alertas	Remover conteúdo de dados pessoais dos logs; auditar acesso administrativo e mudanças de regras.

Multi-tenancy e domínio. Aplicar isolamento por `tenant\_id` a toda tabela de negócio e verificar escopo no servidor, nunca confiar no ID informado pelo cliente. Organizações OSC podem participar de mais de um programa; permissões por relação/convite. Armazenar locale, timezone e moeda ISO desde o início, mas não abrir jurisdições fiscais estrangeiras antes de um mercado validado. Exportar dados em formatos documentados e preservar identificadores portáteis.

Modelo de dados inicial. `tenant`, `user`, `membership`, `organization`, `program`, `call`, `criteria\_version`, `application`, `project`, `need`, `tranche`, `budget\_line`, `commitment\_allocation`, `provider\_profile`, `service\_category`, `provider\_credential`, `service\_request`, `service\_proposal`, `service\_engagement`, `project\_membership`, `scope\_grant`, `task`, `deliverable`, `signature\_record`, `document`, `verification`, `review\_assignment`, `review`, `conflict\_declaration`, `decision`, `commitment`, `milestone`, `evidence`, `indicator\_definition`, `indicator\_value`, `rule\_set`, `fiscal\_rule`, `match\_run`, `match\_factor`, `consent\_record`, `audit\_event`, `integration\_event`, `notification`. Cada serviço tem chave do projeto e da OSC; autorização validada no servidor em cada leitura/escrita. Restrições garantem que alocações e compromissos não excedam o total aprovado; autoria, assinatura e versão são preservadas. Tabelas versionadas/imutáveis para regras, critérios, decisões e evidências; apagar/reter dados conforme políticas e obrigações legais.

API mínima (exemplos de recursos, sem declarar implementação): `POST /v1/programs`; `POST /v1/calls`; `GET/POST /v1/applications`; `POST /v1/applications/{id}/documents`; `POST /v1/reviews/{id}/decision`; `GET /v1/opportunities?filters=...`; `POST /v1/matches/evaluate`; `GET/POST /v1/projects/{id}/service-needs`; `POST /v1/service-providers/search`; `POST /v1/service-engagements`; `POST /v1/tasks`; `POST /v1/signatures`; `POST /v1/commitments`; `POST /v1/milestones`; `POST /v1/evidence`; `GET /v1/audit-events`; `GET /v1/reports/{id}`. Autorização por objeto e projeto, paginação, idempotência em

comandos externos, rate limiting, schema versioning e trilha do autor. OpenAPI versionado e ambiente sandbox.

Painéis e analytics

Papel	Visão principal	Métricas/controles
OSC	Perfil, candidaturas, necessidades/tranches, compromissos e execução	Status, documentos por vencer, valor pedido/comprometido, próximos marcos, evidências e indicadores reportados.
Empresa/instituto	Programas, pipeline, análise, decisões e portfólio	Orçamento comprometido e saldo; território/causa; tarefas e tempos; entregas/evidências; exportação para auditoria. Não chamar orçamento comprometido de impacto.
Prestador convidado	Demandas atribuídas a projetos específicos de OSCs	Escopo autorizado, tarefas, prazos, arquivos entregues, assinatura pendente/registrada e comentários; nenhuma busca sobre projetos de outros clientes.
Administrador da plataforma	Tenants, usuários, fontes, políticas e incidentes	Acesso excepcional auditado; saúde operacional, fila de pedidos de titular, configuração e alertas. Sem acesso rotineiro a conteúdo sensível do cliente.
Analytics agregado	Demanda, causas, território, ticket e tempos	Coortes e denominadores explícitos; supressão de grupos pequenos; agregação/de-identificação e revisão de reidentificação antes de publicar. Taxa de match e conversão não é medida de impacto causal.

No início, analytics serve para operar o programa do próprio cliente e medir o produto. Comparativos entre clientes, ranking público de OSCs, déficit de financiamento e benchmarks só podem ser ativados após base legal, cobertura, qualidade, limiares de privacidade e revisão contratual.

Implantação, administração, uso e desenvolvimento

Guia de deploy. Separar ambientes `local`, `staging` e `production`; configurar infraestrutura como código, domínio/TLS, vault, storage privado, banco gerenciado, backup e alertas antes do primeiro dado real. CI deve executar lint, typecheck, unit/integration tests, migrations em banco descartável, dependências e secrets scan. Deploy com migrações compatíveis retroativamente; aprovação humana de release; feature flags para módulos sensíveis; rollback de aplicação e plano de restauração de dados. Não manter secrets ou contas de loja em máquinas pessoais.

Guia de administrador. Criar tenant; convidar duas contas administrativas; atribuir papéis mínimos; configurar retenção, templates, política de programa, regras e revisores; definir processo para conflitos; monitorar documentos vencidos, permissões e logs; exportar e encerrar tenant sob política contratual. Mudanças de regras fiscais e critérios publicados exigem versionamento, revisor e trilha imutável.

Guia rápido de empresa. Criar programa e objetivo; declarar orçamento, causa/território, elegibilidade obrigatória e perguntas; validar critérios e conflito de avaliadores; analisar a shortlist e suas lacunas; registrar decisão e fundamento; formalizar compromisso fora da plataforma; acompanhar marcos/evidências; exportar relatório e fechar programa.

Guia rápido de OSC. Criar perfil; indicar responsável; preencher só dados pedidos; anexar documentos vigentes; cadastrar iniciativa, orçamento, capacidade, local e metas; revisar declaração antes do envio; acompanhar status e pedidos; reportar alteração e evidências no marco; solicitar correção de dado. O painel distingue sempre dado autodeclarado, extraído automaticamente e verificado por pessoa/fonte.

Guia de desenvolvimento. Repositório, issue tracker, OpenAPI e migrations pertencem à empresa proprietária; instruções locais, `.env.example` sem secrets, seed sintético, execução/teste determinísticos; convenção para versionamento de API, regras e modelos; code review obrigatório; release note e changelog; rotina para atualização de bibliotecas; exportação portátil e plano de handover para trocar equipe/fornecedor.

Recuperação de desastre (DR) — alvo inicial do piloto

Os números abaixo são metas de planejamento a negociar com o cliente, não SLA já contratado: **RPO ≤ 24 h** (máximo de dados que se aceita perder no cenário de desastre) e **RTO ≤ 8 h** (tempo-alvo para voltar a um serviço essencial). Para contratos enterprise, definir objetivos por cliente e custo.

- Backup criptografado e automatizado do banco, com point-in-time recovery e retenção inicial de 30 dias; cópia em conta/região separada segundo avaliação de residência e custo.
- Versionamento de objetos de evidência; política de retenção e deleção aplicada também às cópias de segurança, dentro da janela técnica documentada.
- Infraestrutura recreável por IaC; segredos armazenados em vault com rotação e responsáveis alternativos.
- Runbook com severidade, comandante de incidente, contatos, status page, prioridade por serviço, triagem de integridade e processo de retorno.
- Exercício de restauração trimestral no piloto; teste semestral de continuidade/recuperação e evidência dos resultados. Não considerar backup como validado sem restore real.
- Após incidente: reconciliar registros de auditoria, documentos e commits; notificar clientes/titulares/autoridades quando legalmente devido; registrar lições e plano de correção.

IA: onde usar e onde não usar

Usos com retorno claro: OCR/extrator para preencher rascunho de campos documentais; classificador de causa/território com taxonomia e revisão; detecção de divergência entre cadastro e documento; sumarização de proposta com citações/páginas; assistente de escrita da OSC que sugere clareza sem alterar fatos; copiloto da empresa para consultar o programa e redigir minuta de relatório a partir de evidências já validadas; busca semântica; recomendações explicáveis do motor determinístico.

Não usar para: declarar uma OSC regular; decidir deferimento; afirmar que tributo é dedutível; atribuir risco ético ou fraude sem prova; classificar beneficiários por vulnerabilidade individual; inventar indicadores ou preencher evidência; escrever/assinar prestação de contas como fato; liberar pagamento; tomar decisão que afete pessoa ou organização sem revisão e contestação.

Controles mínimos: extração sempre marcada como rascunho; fonte/página anexada; confiança por campo; confirmação por pessoa; prompt e modelo/versionamento; testes com documentos reais autorizados e sintéticos; redaction de PII; retenção mínima; contrato/provedor revisado; registro de custo; avaliação de viés por porte, território e causa; botão para corrigir; fallback sem IA. Estruturar governança usando as funções Governar, Mapear, Medir e Gerenciar do NIST AI RMF como referência voluntária, não como certificação; para IA generativa, considerar também os riscos e controles específicos do NIST AI 600-1. [21] [34]

LGPD, compliance e governança

O papel de controlador ou operador depende das decisões efetivamente tomadas por finalidade; o contrato não muda sozinho o papel real. Em geral, o cliente define objetivos e critérios do programa; a plataforma pode atuar como operadora nos fluxos desse cliente. Para cadastro de contas, segurança, faturamento e prevenção de abuso, a empresa pode ser controladora independente. Mapear finalidades e papéis por fluxo e formalizar instruções, suboperadores, transferências e atendimento a titulares. [22]

Privacy by design: coletar dados institucionais mínimos; limitar dados pessoais em documentos; bloquear exposição pública por padrão; permissionamento por objeto; retenção por finalidade e calendário; canal de acesso/correção/exclusão; anonimizar analytics quando possível; avaliação de impacto para tratamentos de maior risco; base legal por categoria; consentimento apenas quando apropriado, não como base genérica; gestão de incidente e comunicação conforme regras vigentes da ANPD. A ANPD orienta comunicação de incidentes relevantes pelo controlador segundo prazos e conteúdo regulamentares. [23]

KYC/KYB no produto não é um selo de regularidade. Conferência automática de CNPJ, certidões ou listas deve registrar fonte, data, resultado e limites de cobertura. Para listas de sanções ou PEP, fornecedor e escopo precisam ser contratados; falso positivo exige análise. Conflito de interesse é autodeclarado e também fluxo de governança; a plataforma facilita declaração/abstenção, não garante ausência de conflito.

MROSC. A Lei 13.019/2014 disciplina parcerias entre administração pública e OSC, com instrumentos e prestação de contas próprios. Não deve ser aplicada como rótulo legal a todo grant privado entre empresa e OSC. Se houver parceria pública, exigir configuração por ente, instrumento e plano de trabalho, e seguir norma própria. [24]

Evidências, pagamentos e integridade

Modelar cadeia de evidência: oportunidade → submissão → revisão → decisão → compromisso → execução → atividade/entrega do prestador → evidência → aceite profissional/da OSC → resultado → prestação de contas. Guardar quem anexou, autoria técnica, versão, credencial/escopo quando aplicável, método e evento de assinatura, quando, a qual marco/indicador se refere e se foi revisada. Hash criptográfico pode mostrar que um arquivo não mudou depois do registro; não prova que o conteúdo era verdadeiro na origem. Integrar assinatura eletrônica apropriada somente nos fluxos necessários, com autoria humana identificável e revisão jurídica do tipo de ato. A IA pode organizar e preencher rascunhos, nunca assinar ou converter seus próprios resultados em parecer técnico final. Blockchain não se justifica para um banco de evidências controlado por uma entidade.

No MVP, a plataforma não recebe, mantém em custódia, converte ou distribui doação. Registra compromisso e confirmações enviadas pelas partes. A Lei Rouanet, por exemplo, exige conta específica no nome do beneficiário e regime próprio. Se surgir fluxo de pagamento, usar instituição/gateway com responsabilidades contratuais claras e analisar enquadramento regulatório com especialista; uma página do Banco Central não basta para determinar que a plataforma está ou não sujeita a autorização. [16] [25]

Segurança, ameaças e controles

Ameaça	Impacto	Controles de projeto
Acesso cruzado entre empresas/OSC (BOLA)	Exposição de documentos, decisões ou dados	Autorização em cada requisição/objeto; testes negativos multi-tenant; identificadores não substituem autorização. [26] [33]
Documento malicioso ou URL assinada exposta	Malware, exfiltração ou acesso persistente	Antivírus, allowlist de formatos, URLs curtas, criptografia, isolamento, logs sem conteúdo.
Conta de revisor comprometida	Aprovação ou alteração indevida	MFA, privilégio mínimo, dupla aprovação em decisões críticas e alertas de anomalia.
Prompt injection/extração via documento	Vazamento entre tenants ou instrução maliciosa ao LLM	Tratar documento como dado não confiável; isolamento; sem ferramentas de escrita; redaction; revisão humana.
Falsidade documental/uso de lista desatualizada	Exclusão injusta ou financiamento indevido	Fonte e data; thresholds de certeza; recurso/contestação; humano para sinal incerto.
Ransomware/indisponibilidade	Perda de operação e evidência	Backups imutáveis, restauração testada, DR, MFA administrativa, segmentação e resposta a incidente.
Exfiltração por fornecedor/SDK	Violação de dados pessoais e reputação	Due diligence, DPA, inventário de suboperadores, minimização e atualização de Data Safety.

Adotar OWASP ASVS 5.0 como checklist de verificação de aplicação web e OWASP API Security para autorização, autenticação, limitação de recursos e inventário de endpoint. A verificação deve incluir pentest antes de pagamentos ou escala de dados, além de dependências, SAST/DAST, revisão de código, secrets scanning e testes de permissão. [26] [27] [33]

Princípios operacionais: zero trust entre serviços; least privilege; TLS moderno; criptografia em repouso; KMS; segregação de ambientes; segredo em vault; backups criptografados com restore drills; RPO/RTO definidos antes do contrato; logs de auditoria append-only e acesso restrito; processo de vulnerabilidade e patching; plano de resposta a incidentes; eliminação segura e comprovável.

Registro geral de riscos

Risco (avaliação preliminar)	Probabilidade / impacto	Mitigação e indicador de acompanhamento
Venda lenta / comprador não tem orçamento	Alta / alta	Piloto pago antes de ampliar equipe; medir conversão e tempo de contratação.
Oferta insuficiente ou dados incompletos de OSCs	Alta / alta	Curadoria concierge, apoio de cadastro, medir completude e tempo de resposta; não abrir marketplace amplo.
Perfil, credencial ou parecer profissional incorreto; falsa aparência de certificação	Média / alta	Fonte e data, revisão/contestação, responsabilidade técnica identificada, vedar selo geral e não automatizar conclusão; medir correções, falsos positivos e atualização de credenciais.
Diretório ou workflow cria discriminação, exposição indevida ou risco trabalhista/consumerista	Média / alta	Pesquisa por critérios objetivos, acesso mínimo por projeto, sem ranking sensível, análise da relação concreta, canal de recurso e revisão jurídica; medir reclamações e incidentes por categoria/território.
Interpretação fiscal errada ou regra revogada	Média / muito alta	Regra versionada com fonte oficial, data, especialista revisor e teste; indicador: regra sem revisão vigente = zero em produção.
Conflito de interesse ou alegação enganosa de "impacto verificado"	Média / alta	Rótulos exatos de origem/nível de revisão, declaração/abstenção e canal de contestação; amostragem de auditoria.
Incidente ou vazamento de documentos	Média / muito alta	Minimização, acesso por objeto, logs, encryption, backup, teste de segurança e plano de resposta; tempo para contenção e taxa de correção.
Captura de recursos, custódia ou intermediação exige análise regulatória	Baixa no MVP / muito alta se ativado	Desabilitar pagamento/custódia até parecer e desenho com prestador regulado; não ativar split por configuração improvisada.
Viés de score favorece OSCs maiores/urbanas/documentadas	Média / alta	Score explicável, confiança separada, avaliação segmentada, mecanismos de correção e revisão humana; acompanhar distribuição de shortlist.

Risco (avaliação preliminar)	Probabilidade / impacto	Mitigação e indicador de acompanhamento
IA alucina ou usa dados além da finalidade	Média / alta	Fontes/citações, saída em rascunho, provider gateway, revisão, retenção restrita e fallback; medir taxa de erro por campo.
Dependência de fornecedor/lock-in	Média / média	Exportação, padrões abertos, abstração de IA, backup independente, repositórios e domínios na conta da empresa.
Relatório ESG é usado como prova causal sem base	Média / alta	Distinguir atividade, produto, resultado e contribuição; comunicar limites de atribuição e método de indicador.

Probabilidade e impacto são hipóteses qualitativas iniciais para direcionar descoberta. Devem ser atualizados após piloto, incidentes, entrevistas e revisão legal.

Roadmap, testes e critérios de saída

Fase	Entregas	Gate para avançar
0. Descoberta (2–4 semanas)	15–20 entrevistas; escolha de nicho; fluxo atual mapeado; LOI/orçamento; parecer inicial de pagamentos, fiscal e LGPD	Pelo menos 1 comprador com problema e orçamento identificados; não validar só por elogios
1. Piloto (8–12 semanas)	Web app; perfil OSC; programa, edital, candidaturas; revisão/aprovações; evidências; colaboração por convite com prestadores em projetos de OSC; 1 região; operação concierge	Uso em fluxo real; autoria/assinatura e permissões verificadas; dados completos; 1 contrato pago/renovação discutida; sem bloqueio crítico de segurança
2. Produto regional (3–6 meses)	Multi-tenant endurecido; dashboards; relatórios; importação/exportação; onboarding repetível; diretório opt-in e pesquisável com fontes/credenciais controladas	Repetição de programas e economia de suporte por conta; revisão do diretório e canal de contestação operando
3. Escala Brasil (6–12 meses)	Catálogo maior, regra fiscal com governança, integrações; contratação comercial	3+ clientes pagantes renovando/coorte, referências, serviço repetível
4. Enterprise (após sinais de escala)	SSO, SCIM, SLA, pentest, auditoria, integrações corporativas, implantação formal	Compradores com requisitos e orçamento; segurança comprovada
5. Internacionalização	locale/moeda/jurisdição; pesquisa legal e de parceiros por país	Nova jurisdição aprovada, regras locais e suporte definidos

Prazos são estimativas de planejamento, não promessa de entrega. Três OSCs e uma empresa podem validar a experiência inicial, mas não validam segurança empresarial, unit economics nem qualidade de ranking em escala.

Testes mínimos: unitários de regras fiscais e score; property-based tests de elegibilidade; testes de API; integração com storage; permissões multi-tenant; regressão de critérios; E2E de cadastro até prestação de contas; teste de upload malicioso; acessibilidade; performance sob carga; restores de backup; incident response tabletop; avaliação de IA por amostra

rotulada. Casos sintéticos pedidos no briefing devem cobrir OSC válida/irregular, empresa elegível/não elegível, conflito, documento expirado, combinação forte/fraca e hard blocker. Regras fiscais precisam de aprovação humana de cada versão antes do deploy.

Web, Google Play e Apple App Store

Não há necessidade comprovada de aplicativo nativo no MVP. Começar com PWA responsiva, links de convite e upload pelo navegador. Aplicativo Android/iOS deve ser construído quando notificação, uso offline, câmera de campo ou experiência de voluntariado justificar o custo. Se publicado, funcionalidade, políticas, privacy label/Data Safety, suporte, exclusão de conta e configurações devem corresponder exatamente ao backend e ao inventário de SDKs. A Apple exige política de privacidade e exclusão de conta iniciada no app para apps que permitem criar contas; suas declarações de privacidade devem também refletir parceiros/SDKs. O Google Play exige declarações de Data Safety e fluxo de exclusão dentro e fora do app. [28] [29] [30] [31] [32]

Checklist condicional de release. Web/PWA: manifest, ícones, deep links compatíveis, domínio/TLS, termos e política, navegação por teclado e verificação de responsividade. Android: identificador de pacote, versionamento, keystore mantida em vault, permissões mínimas, testes internos, formulário Data Safety e URL externa para pedido de exclusão. iOS: bundle ID organizacional, certificado/provisioning sob conta da empresa, TestFlight, metadados, privacy nutrition label e fluxo de exclusão. Ambos: inventário de SDKs e dados, ambiente de produção separado, alerta/rollback, suporte e release notes. São orientações documentais; não existem builds, assinaturas ou cadastros de loja nesta entrega.

Status a declarar corretamente: **READY FOR BUILD** significa que requisitos e ambientes foram preparados; **BUILD GENERATED** significa artefato compilado; **SUBMITTED** significa enviado à revisão; **PUBLISHED** só após aprovação e disponibilização pública. Nenhum desses estados é alcançado apenas por documentação.

Propriedade intelectual e portabilidade

Ativo	Titularidade esperada	Controle e ação contratual
Código original, infraestrutura como código e testes	Empresa proprietária do produto	Cessão de direitos patrimoniais válida, inventário de contribuidores, repositório em conta própria
Nome, marca e identidade visual	Empresa/cliente que contrata criação	Busca de anterioridade e registro de marca no INPI; contratos de cessão/licença
Especificações, schema, APIs e documentação	Empresa proprietária	Licença de terceiros identificada; exportação OpenAPI e migrações
Taxonomias, regras, prompts e workflows	Empresa, ressaltados dados/terceiros	Versionamento, controle de acesso, segredo empresarial; não afirmar patenteabilidade

Ativo	Titularidade esperada	Controle e ação contratual
Dados das OSCs, empresas e beneficiários	Direitos e papéis definidos por lei/contratos	Finalidade, acesso, portabilidade e retenção; dados pessoais não viram propriedade irrestrita da plataforma
Modelos de terceiros, SDKs e open source	Conforme licença/provedor	SBOM, licença, avisos, substituto, análise de restrições e política de dados do fornecedor
Conteúdo/documentos enviados por usuário	Autor ou titular correspondente	Termos limitam licença ao serviço; garantir direitos de uso e apagar/reter conforme obrigação
Domínio, cloud, chaves e contas de lojas	Empresa proprietária	Registrados na organização, MFA, recuperação e dois administradores autorizados

Criar contrato de desenvolvimento com cessão explícita de direitos patrimoniais sobre entregas sob encomenda, obrigação de entregar código-fonte e documentação, credenciais e pipelines em contas do proprietário, garantia de inventário de dependências, cláusula de cooperação na transição e vedação de dados secretos no ambiente pessoal do fornecedor. A cessão deve ser revisada por jurídico; conceitos abstratos ou métodos não são automaticamente monopolizáveis.

Registro de dependências externas

Dependência	Uso	Risco/controle
Cloud e armazenamento S3-compatible	Hospedagem e arquivos	Infraestrutura desacoplada; backup exportável; contrato e região de dados revisados
Provedor de identidade	Login/SSO	OIDC, exportação de usuários e plano de fallback
LLM/OCR	Extração e assistência	Gateway substituível; nenhum uso de dado sem autorização; revisão de retenção/treino; limite de custo
Gateway de e-mail/WhatsApp/push	Alertas	Opt-in e templates; opção de troca; nada crítico depende de mensagem não confirmada
Fornecedor de KYB/listas	Verificações	Fonte/cobertura e SLA conhecidos; falsos positivos escalados a humano
Gateway de pagamento, futuro	Transferência, se habilitada	Não custódia; jurídico/regulatório antes de ativar; evidência de conciliação
Open source	Frameworks, bibliotecas e testes	SBOM, licenças, atualização e vulnerabilidades
Apple/Google	Distribuição nativa	Contas da empresa, política atual e revisão antes de cada release

Auditoria final simulada

Papel	Questionamento	Conclusão / correção incorporada
CEO/Investidor	Quem paga e por que agora?	Venda a comprador com programas recorrentes; não assumir que o valor total do investimento social vira TAM
CFO	SaaS sustentável com ticket inicial?	Piloto pago e preço experimental; medir implantação, suporte e CAC por coorte
CTO	Arquitetura superdimensionada ou lock-in?	Modular monolith, PostgreSQL, web-first; evitar microserviços, Redis, Elasticsearch e apps nativos antes da necessidade
CISO	Dados e tenants protegidos?	Autorização por objeto/tenant, MFA, armazenamento privado, teste OWASP, backup restaurável
Fiscal	Benefício ou limite pode estar desatualizado?	Fiscal engine versionado, LC 222/2025 e fontes oficiais, revisão humana; sem garantia de dedução
Jurídico/LGPD	Quem controla dados e fundos?	Papéis definidos por finalidade; sem custódia no MVP; avaliação jurídica para cada mecanismo
Product Manager	Swipe gera decisão melhor?	Removido do centro; shortlist comparável, status, critérios e fluxo de aprovação
Store reviewer	Política de dados/conta compatível?	Não nativo no MVP; se for publicado, privacidade, Data Safety e exclusão de conta implementadas e testadas

Riscos residuais que não se resolvem com documentação: interpretação de legislação tributária e regimes locais; enquadramento da plataforma se houver pagamentos/intermediação; qualidade de fontes de due diligence; responsabilidade por dados incorretos; ciclo longo de venda corporativa; cobertura e continuidade operacional de OSCs; segurança efetiva que só auditoria/teste de software pode verificar.

Auditoria de release e escopo desta entrega

Este arquivo é um **resultado de estratégia, pesquisa de mercado e blueprint técnico**. Não é software, protótipo executável nem parecer fiscal/jurídico. Não foram implementados código, app web, aplicativo mobile, backend, base de dados, integração de IA, mecanismo em produção, testes de software, pipeline de publicação ou pacote `FINAL\_FULL\_RELEASE.zip`. Portanto, não afirmar que a plataforma está pronta para build, submetida ou publicada.

Estado do pedido	Resultado nesta entrega
100% IMPLEMENTADO	Relatório DOCX de estratégia e blueprint produzido.
IMPLEMENTADO E TESTADO	Arquivo DOCX validado; estrutura, tabelas, conteúdo e renderização visual inspecionados. Nenhum teste de produto/software foi executado.

Estado do pedido	Resultado nesta entrega
IMPLEMENTADO MAS DEPENDE DE CONFIGURAÇÃO EXTERNA	Nenhum software implementado; dependerá de contas, credenciais, cloud, fornecedores e aprovações após desenvolvimento.
NÃO IMPLEMENTADO	Source code completo, web/mobile/backend/database/AI/Admin, testes, deploy, build e publicação, arquivo zip e README de execução.
REQUER VALIDAÇÃO HUMANA/JURÍDICA/FISCAL	Regras tributárias por exercício/mecanismo; pagamentos e intermediação; LGPD e contratos; marcas e cessões; abordagem por estado/município; política de lojas.

Próximas cinco decisões operacionais: (1) escolher território e causa inicial; (2) obter comprador âncora e orçamento; (3) mapear fluxo vigente e formulários; (4) contratar revisão jurídica/fiscal para 1-2 mecanismos reais; (5) aprovar escopo do piloto pago antes de contratar desenvolvimento maior.

Referências

- [1] Ipea, *O Perfil das Organizações da Sociedade Civil no Brasil (2016–2025)* — dados até 23 maio 2025; seção de mercado de trabalho e porte. https://bookdown.org/mosc_ipea/relatorio-estatistico-MOSC-2025/
- [2] GIFE, *Censo GIFE 22–23*. <https://gife.org.br/especial-redegife-censo-gife-22-23/>
- [3] Comunitas, *Fortalecimento do investimento social corporativo — Rede BISC*. <https://comunitas.org.br/fortalecimento-do-investimento-social-corporativo/>
- [4] Prosas, página institucional e funcionalidades de editais e monitoramento. <https://prosas.com.br/>
- [5] Incentiv.me, página institucional. <https://incentiv.me/>
- [6] Benevity, pricing e módulos Enterprise Impact Platform. <https://benevity.com/pricing>
- [7] Submittable, preços e produtos de CSR/grant management. <https://www.submittable.com/pricing>
- [8] Good Grants, planos e preços. <https://goodgrants.com/pricing/>
- [9] Benfeitoria, plataforma de financiamento coletivo. <https://benfeitoria.com/>
- [10] Doare, plataforma de doações. <https://doare.org/>
- [11] Blackbaud YourCause, produto de CSR/employee giving. <https://www.blackbaud.com/solutions/yourcause>
- [12] Goodera, plataforma de voluntariado corporativo. <https://www.goodera.com/>
- [13] B1G1, modelo de giving para empresas. <https://b1g1.com/>
- [14] Ministério da Cultura, página da Lei Rouanet/Lei de Incentivo à Cultura. <https://www.gov.br/cultura/pt-br/assuntos/acoes-programas-e-politicas/lei-rouanet-1>
- [15] Ministério da Cultura, Instrução Normativa MinC nº 29, de 29 jan. 2026. <https://www.gov.br/cultura/pt-br/aceso-a-informacao/legislacao-e-normativas/instrucao-normativa-minc-no-29-de-29-de-janeiro-de-2026>
- [16] Planalto, Lei nº 8.313/1991 consolidada, em especial arts. 18 e 26–29. https://www.planalto.gov.br/ccivil_03/leis/l8313cons.htm
- [17] Planalto, Lei Complementar nº 222/2025, incentivos ao esporte, regras transitórias e revogação da Lei 11.438/2006. https://www.planalto.gov.br/ccivil_03/leis/lcp/Lcp222.htm
- [18] Planalto, Lei nº 11.438/2006 (página marcada como revogada pela LC 222/2025). https://www.planalto.gov.br/ccivil_03/ato2004-2006/2006/lei/l11438.htm

- [19] Receita Federal, *Destinação na Declaração*. <https://www.gov.br/receitafederal/pt-br/assuntos/meu-imposto-de-renda/preenchimento/manual-mir/destinacao-na-declaracao>
- [20] Apple, App Store Review Guidelines, seção 5.1 Privacy e regras relacionadas. <https://developer.apple.com/app-store/review/guidelines/>
- [21] NIST, AI Risk Management Framework. <https://www.nist.gov/itl/ai-risk-management-framework>
- [22] ANPD, Guia orientativo para definições dos agentes de tratamento e do encarregado. <https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia-orientativo-para-definicoes-dos-agentes-de-tratamento-de-dados-pessoais-e-do-encarregado>
- [23] ANPD, Comunicação de Incidentes de Segurança. <https://www.gov.br/anpd/pt-br/assuntos/comunicacao-de-incidentes-de-seguranca-cis>
- [24] Planalto, Lei nº 13.019/2014 compilada (MROSC). https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l13019compilado.htm
- [25] Banco Central do Brasil, Arranjos de Pagamento. <https://www.bcb.gov.br/estabilidadefinanceira/arranjospagamento>
- [26] OWASP, API Security Top 10 — API1:2023 Broken Object Level Authorization. <https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/>
- [27] OWASP, Application Security Verification Standard (ASVS), versão estável indicada pelo projeto. <https://owasp.org/projects/asvs>
- [28] Apple, Offering account deletion in your app. <https://developer.apple.com/support/offering-account-deletion-in-your-app/>
- [29] Google Play, User Data policy, Data safety e Account Deletion. <https://support.google.com/googleplay/android-developer/answer/10144311?hl=en>
- [30] Planalto, Lei nº 13.709/2018 (LGPD), texto vigente consultado em 4 out. 2026. https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- [31] Apple, App privacy details on the App Store. <https://developer.apple.com/app-store/app-privacy-details/>
- [32] Google Play, User data deletion requirements. <https://support.google.com/googleplay/android-developer/answer/13327111?hl=en>
- [33] OWASP, API3:2023 Broken Object Property Level Authorization. <https://owasp.org/API-Security/editions/2023/en/0xa3-broken-object-property-level-authorization/>
- [34] NIST, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1). <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- [35] Receita Federal, Deduções incentivadas — Manual do Imposto de Renda, consulta em 4 out. 2026. <https://www.gov.br/receitafederal/pt-br/assuntos/meu-imposto-de-renda/preenchimento/manual-mir/pagamentos-ou-doacoes/deducoes-incentivadas>
- [36] Planalto, Lei nº 12.715/2012 consolidada, Pronon e Pronas/PCD; art. 4º com redação dada pela Lei nº 15.513/2026. https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2012/lei/l12715.htm
- [37] Ministério da Saúde, Pronon e Pronas/PCD — habilitação e submissão de propostas. <https://www.gov.br/saude/pt-br/se/pronon-e-pronas-pcd>
- [38] Planalto, Lei nº 12.594/2012, art. 87, alteração do art. 260 do ECA e limites/documentação das doações a fundos da criança/adolescente. https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2012/lei/l12594.htm
- [39] Planalto, Lei nº 12.213/2010 consolidada, Fundo da Pessoa Idosa e dedução de doações. https://www.planalto.gov.br/ccivil_03/_ato2007-2010/2010/lei/l12213.htm

- [40] Planalto, Constituição da República Federativa do Brasil, arts. 1º, 3º, 5º, 6º e 7º.
https://www.planalto.gov.br/ccivil_03/constituicao/constituicao.htm
- [41] Planalto, Lei nº 8.078/1990 compilada, Código de Defesa do Consumidor, arts. 2º–4º.
https://www.planalto.gov.br/ccivil_03/leis/l8078compilado.htm
- [42] Planalto, Decreto-Lei nº 5.452/1943 compilado, Consolidação das Leis do Trabalho, arts. 2º, 3º e 9º.
https://www.planalto.gov.br/ccivil_03/decreto-lei/del5452.htm
- [43] Planalto, Lei nº 14.063/2020, assinaturas eletrônicas em interações com entes públicos, atos de pessoas jurídicas e questões de saúde.
https://www.planalto.gov.br/ccivil_03/_ato2019-2022/2020/lei/l14063.htm
- [44] Prosas, Termos de Uso, funcionalidades gratuitas para proponentes e política comercial para patrocinadores. <https://produtos.prosas.com.br/termos-de-uso>
- [45] Doare, planos, mensalidades, taxas por meio de pagamento e recursos incluídos.
<https://doare.org/planos>
- [46] AWS Marketplace, Submittable Grants Management System, pacotes Professional/Premium e preços por prazo. <https://aws.amazon.com/marketplace/pp/prodview-hqnqffpbpev74>
- [47] B1G1, planos públicos de membership e faixas de negócio. <https://b1g1.com/join-us>
- [48] Benevity, registro, perfil e participação gratuitos para nonprofits. <https://benevity.com/nonprofits>
- [49] Blackbaud, política de cotação baseada em organização, usuários, módulos e suporte.
<https://www.blackbaud.com/pricing>
- [50] Benfeitoria, Termos de Uso — comissão voluntária e condições de pagamento.
<https://benfeitoria.com/termos-de-uso>
- [51] Goodera, integração API com Benevity (criação de eventos e sincronização de inscrições), anúncio de fev. 2026. <https://www.goodera.com/news/goodera-and-benevity-api-integration-goes-live-enabling-faster-scalable-corporate-volunteering>
- [52] Benevity, Developer Documentation — APIs REST/OpenAPI e integrações.
<https://developer.benevity.org/>
- [53] Good Grants, Security — infraestrutura, regiões de dados e certificações divulgadas.
<https://goodgrants.com/features/security/>